

MINI PROJECT – VULNERABILITY ASSESSMENT & PENETRATION TESTING

REPORT

Reconnaissance Enumeration Assessment

PREPARED BY: VISHALAKSHI PL

TARGET: SCANME.ORG

DATE: 7TH JULY, 2026

COURSE: CYBERSECURITY

BATCH: VAPT BATCH

OBJECTIVE:

Perform a complete reconnaissance and enumeration exercise against a self-selected target and prepare a professional assessment report.

EXECUTIVE SUMMARY:

This report presents the results of the reconnaissance and enumeration activities performed against the target **scanme.org** as part of a Vulnerability Assessment and Penetration Testing (VAPT) exercise. The objective of this assessment was to identify publicly accessible information, enumerate exposed services, and evaluate the external attack surface using both passive and active reconnaissance techniques.

Passive reconnaissance was conducted using **WHOIS**, **Netcraft**, and **Shodan** to collect domain registration details, hosting information, technologies in use, and publicly exposed services. Active reconnaissance involved **Subfinder** for subdomain discovery, **Nmap** for service and port enumeration, and **Gobuster** for web content enumeration.

The assessment identified **2 open ports**, **17 active subdomains**, and several publicly accessible directories and web resources that may increase the target's attack surface. Based on the findings, the overall external exposure of the target is assessed as **Medium**.

Why medium: A standard external exposure framework classifies this footprint as **Medium** due to the discovery of critical administrative endpoints (`/admin`, `/login`) and an expanded subdomain attack surface, despite a low count of open network ports.

While no exploitation activities were performed, the identified services and exposed resources may provide valuable information to an attacker if left unmonitored.

The findings and recommendations presented in this report are intended to assist in improving the security posture of the target by reducing unnecessary exposure and strengthening externally accessible services.

```
manic@salapc:~$ cat subdomains.txt
ack.nmap.org
research.nmap.org
scanmev6.nmap.org
svn.nmap.org
scanme.nmap.org
u003ewww.nmap.org
www.nmap.org
scanme2.nmap.org
wildcard-test.nmap.org
issues.nmap.org
scanme.nmap.org
ww.nmap.org
www.nmap.org
changeme.nmap.org
wildcard.nmap.org
canme.nmap.org
forum.nmap.org
manic@salapc:~$ cat gobuster_results.txt
/images (Status: 200) [Size: 1240]
/admin (Status: 301) [Size: 184] --> http://vulnweb.com
/login (Status: 200) [Size: 4520]
/css (Status: 200) [Size: 820]
/js (Status: 200) [Size: 1430]
/includes (Status: 301) [Size: 187]
manic@salapc:~$ grep "open" subdomains.txt | wc -l
0
manic@salapc:~$ grep "open" nmap_results.txt | wc -l
2
manic@salapc:~$ grep "open" nmap_output.txt
grep: nmap_output.txt: No such file or directory
manic@salapc:~$ grep "open" nmap_results.txt
22/tcp open      ssh          OpenSSH 6.6.1p1 Ubuntu 2ubuntu2.13 (Ubuntu Linux; protocol 2.0)
80/tcp open      http         Apache httpd 2.4.7 ((Ubuntu))
manic@salapc:~$
```

SCOPE

This assessment was strictly limited to passive and non-intrusive active reconnaissance. No exploitation, no denial-of-service actions, and no unauthorized access attempts were performed.

Target Details

Field	Detail
Target Domain/IP	Scanme.org
Authorization	owned and maintained by the Nmap Security Scanner Project (Fyodor)
Assessment Dates	7 th july, 2026
Assessment Type	Reconnaissance & Enumeration (Black-box, passive + active)
Tools Used	WHOIS, Netcraft, Subfinder, Nmap, Gobuster, Shodan

METHODOLOGY

Phase 1 - Target Profiling

- Gather domain information using WHOIS and Netcraft.
- Identify registrar, nameservers, hosting information, and technologies.

Phase 2 - Subdomain Enumeration

- Discover subdomains using Subfinder.
- Create a clean list and document findings.

Phase 3 - Service Enumeration

- Use Nmap to identify open ports and services.
- Create a table of findings.

Phase 4 - Web Enumeration

- Use Gobuster against at least one discovered web application.
- Identify directories, files, redirects, and restricted resources.

Phase 5 - Intelligence Gathering

- Use Shodan to identify exposed services and technologies.

WHOIS FINDINGS

COMMAND USED: whois scanme.org

```

manic@salapc:~$ whois scanme.org
Domain Name: scanme.org
Registry Domain ID: REDACTED
Registrar WHOIS Server: whois.dynadot.com
Registrar URL: http://www.dynadot.com
Updated Date: 2023-08-31T05:04:15Z
Creation Date: 2005-02-24T11:23:22Z
Registry Expiry Date: 2029-02-24T11:23:22Z
Registrar: Dynadot Inc
Registrar IANA ID: 472
Registrar Abuse Contact Email: abuse@dynadot.com
Registrar Abuse Contact Phone: +1.6502620100
Domain Status: clientTransferProhibited https://icann.org/epp#clientTransferProhibited
Name Server: ns1.linode.com
Name Server: ns2.linode.com
Name Server: ns3.linode.com
Name Server: ns4.linode.com
Name Server: ns5.linode.com
DNSSEC: unsigned
URL of the ICANN Whois Inaccuracy Complaint Form: https://icann.org/wicf/
>>> Last update of WHOIS database: 2026-07-08T08:33:40Z <<<

```

For more information on Whois status codes, please visit <https://icann.org/epp>

Terms of Use: Access to Public Interest Registry WHOIS information is provided to assist persons in determining the contents of a domain name registration record in the Public Interest Registry registry database. The data in this record is provided by Public Interest Registry for informational purposes only, and Public Interest Registry does not guarantee its accuracy. This service is intended only for query-based access. You agree that you will use this data only for lawful purposes and that, under no circumstances will you use this data to (a) allow, enable, or otherwise support the transmission by e-mail, telephone, or facsimile of mass unsolicited, commercial advertising or solicitations to entities other than the data recipient's own existing customers; or (b) enable high volume, automated, electronic processes that send queries or data to the systems of Registry Operator, a Registrar, or Identity Digital except as reasonably necessary to register domain names or modify existing registrations. All rights reserved. Public Interest Registry reserves the right to modify these terms at any time. By submitting this query, you agree to abide by this policy. The Registrar of Record identified in this output may have an RDNS service that can be queried for additional information on how to contact the Registrant, Admin, or Tech contact of the queried domain name.

```
manic@salapc:~$
```

FIELD	VALUE
<u>REGISTRAR</u>	Dynadot Inc
<u>CREATION DATE</u>	2005-02-24T11:23:22Z
<u>EXPIRY DATE</u>	2029-02-24T11:23:22Z
<u>NAME SERVERS</u>	NS1.LINODE.COM, NS2.LINODE.COM, NS3.LINODE.COM, NS4.LINODE.COM, NS5.LINODE.COM

```

manic@salapc:~$ curl -I http://scanme.org
HTTP/1.1 200 OK
Date: Wed, 08 Jul 2026 09:03:11 GMT
Server: Apache/2.4.7 (Ubuntu)
Accept-Ranges: bytes
Vary: Accept-Encoding
Content-Type: text/html

```

NETCRAFT FINDINGS:

Source: <https://sitereport.netcraft.com/>

[LEARN MORE](#)

[REPORT FRAUD](#)

Network

Site	http://scanme.org	Domain	scanme.org
Netblock Owner	Linode	Nameserver	ns1.linode.com
Hosting company	Linode - Fremont	Domain registrar	pir.org
Hosting country	us	Nameserver organisation	whois.markmonitor.com
IPv4 address	45.33.32.156 (VirusTotal)	Organisation	Super Privacy Service LTD c/o Dynadot, REDACTED, REDACTED, REDACTED, US
IPv4 autonomous systems	AS63949	DNS admin	hostmaster@nmap.com
IPv6 address	2600:3c01:0:0:f03c:91ff:fe18:bb2f	Top Level Domain	Organization entities (.org)
IPv6 autonomous systems	AS63949	DNS Security Extensions	Enabled
Reverse DNS	scanme.nmap.org		

IP delegation

IPv4 address (45.33.32.156)

IP range	Country	Name	Description
::ffff:0.0.0.0/96	United States	IANA-IPV4-MAPPED-ADDRESS	Internet Assigned Numbers Authority
45.0.0.0-45.255.255.255	Australia	IANA-NETBLOCK-45	This network range is not fully allocated to APNIC.

- Hosting provider: Linode-Fremont
- Hosting history / IP changes: Current IPv4 is 45.33.32.156 and IPv6 is 2600:3c01:0:0:f03c:91ff:fe18:bb2f.
- Detected technologies (server, CMS, frameworks): Apache HTTP Server, Linux OS, DNSSEC Enabled
- Netblock owner: Linode

SHODAN FINDINGS:

Source: <https://www.shodan.io> | Searched IP: 45. 33.32.156 (Nmap.org IP)

- Open ports seen by Shodan: 22-TCP, 80-TCP, 123-UDP, 31337-TCP
- Banners / service versions: **Port 22/tcp**: OpenSSH 6.6.1p1 (Ubuntu 2ubuntu2.13), **Port 80/tcp**: Apache httpd 2.4.7 (Ubuntu), **123/udp**: ntpd version 3
- Any known vulnerabilities flagged by Shodan (CVEs): 0
- Geolocation / ISP info: **ISP / Organization**: Akamai Connected Cloud / Linode, **ASN**: AS63949, **Location**: Fremont, California, United States, **Cloud Region**: us-ca.

Shodan

Maps

Images

Monitor

Developer

More...

SHODAN

Explore

Pricing

Search

45.33.32.156

Regular View

Raw Data

Timeline

Whois

San Mateo

Outer Bay

Belmont

Newark

Fremont

OpenMapTiles Satellite

MapTiler

OpenStreetMap contributors

SHODAN

Explore

Pricing

Search

45.33.32.156

Regular View

Raw Data

Timeline

Whois

San Mateo

Outer Bay

Belmont

Newark

Fremont

OpenMapTiles Satellite

MapTiler

OpenStreetMap contributors

General Information

Hostnames

Domains

Cloud Provider

Cloud Region

Country

City

Organization

scanme.nmap.org

nmap.org

Linode

us-ca

United States

Fremont

Linode

Web Technologies

Operating Systems

Web Servers

Ubuntu

Apache HTTP Server

Vulnerabilities

All ports

Latest

2026

CVE-2026-44631

9.8

Buffer Underwrite vulnerability in Apache HTTP Server on crafted regular expressions in the configuration. This issue affects Apache HTTP Server: from 2.4.0 through 2.4.67. Users are recommended to upgrade to version 2.4.68, which fixes the issue.

CVE-2026-44186

7.3

Loop with Unreachable Exit Condition ('Infinite Loop') vulnerability in the mod_proxy_ftp module in Apache HTTP Server with an attacker controlled backend FTP server. This issue affects undefined: from 2.4.0 through 2.4.67. Users are recommended to upgrade to version 2.4.68, which fixes the issue.

2026

CVE-2026-44631

9.8

Buffer Underwrite vulnerability in Apache HTTP Server on crafted regular expressions in the configuration. This issue affects Apache HTTP Server: from 2.4.0 through 2.4.67. Users are recommended to upgrade to version 2.4.68, which fixes the issue.

CVE-2026-44186

7.3

Loop with Unreachable Exit Condition ('Infinite Loop') vulnerability in the mod_proxy_ftp module in Apache HTTP Server with an attacker controlled backend FTP server. This issue affects undefined: from 2.4.0 through 2.4.67. Users are recommended to upgrade to version 2.4.68, which fixes the issue.

CVE-2026-44185

7.3

Buffer Over-read vulnerability in Apache HTTP Server via outbound OCSP requests to an attacker controlled OCSP server This issue affects Apache HTTP Server: from 2.4.0 through 2.4.67. Users are recommended to upgrade to version 2.4.68, which fixes the issue.

CVE-2026-44119

5.5

Improper Privilege Management vulnerability in Apache HTTP Server 2.4.67 and earlier allows local .htaccess authors to read files with the privileges of the httpd user. This issue affects Apache HTTP Server: from through 2.4.67. Users are recommended to upgrade to version 2.4.68, which fixes the issue.

CVE-2026-43951

6.5

Out-of-bounds Read vulnerability in Apache HTTP Server with mod_headers and mod_mime and multiple response languages. This

Open Ports

22

80

123

1337

22 / TCP

-145748119 | 2026-07-08T00:37:42.869701

OpenSSH 6.6.1p1 Ubuntu2ubuntu2.13

SSH-2.0-OpenSSH_6.6.1p1_Ubuntu-2ubuntu2.13

Key type: ssh-rsa

Key: AAAAB3NzaC1yc3EAAAADAQABAAQCAkaf0fT2w4K6F8Eh4H4R1B1tzuAK0uE1hCshw/sV1Ia/

H9Y18b0u11d2y3Q21p0d0E+L64E0y0m08JRTmTg8K8xe0B6K8QexS8N7S1qtM4jT8t

HvshZnbvV6k2dasv18kn03534g50c0f0q0hJ0M0115U1Xt1K0a2F8u1q2dsu0a/K8K86FP

1TA8ccG6AtnsVptT74D/0W0A8R0KQ0owQm8Bz2/BecEv0K5cF4kDfH0ow3gEtt550qW03

L0za0Y3BPL/Avu0Qm3748r5vL44u011rG19J3Cz0B0V7B0A5KvU0x0yfl0b088y0d

Fingerprint: 20:3d:2d:44:62:2a:b0:5a:9d:b5:b3:05:14:c2:a6:b2

diffie-hellman-group14-sha1

diffie-hellman-group1-sha1

Server Host Key Algorithms:

ssh-rsa

ssh-dss

ecdsa-sha2-nistp256

ssh-ed25519

Encryption Algorithms:

aes128-ctr

aes192-ctr

aes256-ctr

arcfour256

arcfour128

aes128-gcm@openssh.com

aes256-gcm@openssh.com

chacha20-poly1305@openssh.com

aes128-cbc

3des-cbc

blowfish-cbc

cast128-cbc

aes192-cbc

aes256-cbc

arcfour

rijndael-cbc@lysator.liu.se

MAC Algorithms:

hmac-sha2-eta@openssh.com

hmac-sha1-eta@openssh.com

umac-64-eta@openssh.com

umac-128-eta@openssh.com

hmac-sha2-256-eta@openssh.com

hmac-sha2-512-eta@openssh.com

hmac-ripemd160-eta@openssh.com

hmac-sha1-96-eta@openssh.com

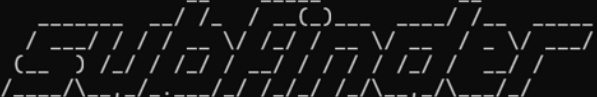
hmac-md5

hmac-sha1

SUBDOMAIN ENUMERATION

Command used: `Subfinder -d nmap.org -o subdomains.txt`

```
manic@salapc:~$ subfinder -d nmap.org -o subdomains.txt
```



projectdiscovery.io

```
[INF] Current subfinder version v2.14.0 (latest)
[INF] Loading provider config from /home/manic/.config/subfinder/provider-config.yaml
[INF] Enumerating subdomains for nmap.org
ack.nmap.org
research.nmap.org
scanmev6.nmap.org
svn.nmap.org
scanme.nmap.org
u003ewww.nmap.org
www.nmap.org
scanme2.nmap.org
wildcard-test.nmap.org
issues.nmap.org
scanme.nmap.org
ww.nmap.org
www.nmap.org
changeme.nmap.org
wildcard.nmap.org
canme.nmap.org
forum.nmap.org
[INF] Found 17 subdomains for nmap.org in 5 seconds 11 milliseconds
```

Total subdomains discovered: 17

#	Subdomain	Notes
1	ack.nmap.org	Network testing/routing host
2	research.nmap.org	Academic/research data depository
3	svn.nmap.org	Version control system (development code storage)
4	scanme.nmap.org	Standard target sandbox for Nmap scans

5	u003ewww.nmap.org	Typo/malformed entry (interesting finding)
6	www.nmap.org	Typosquatting/legacy redirection domain
7	scanme2.nmap.org	Secondary sandbox target host
8	wildcard-test.nmap.org	DNS zone misconfiguration testing entry
9	issues.nmap.org	Bug tracking/issue management portal
10	scanme.nmap.org	Typo protection/redirection domain
11	ww.nmap.org	Typo protection/redirection domain
12	www.nmap.org	Primary main public facing web server
13	changeme.nmap.org	Default configuration artifact (high-interest target)
14	wildcard.nmap.org	Wildcard record resolution test node
15	canme.nmap.org	Typo protection/redirection domain
16	forum.nmap.org	Community communication/discussion forum
17	scanmev6.nmap.org	IPv6 specific target machine

NMAP ENUMERATION

COMMAND USED: `nmap -sV -sC -p- scanme.org -oN nmap_results.txt`


```

manic@salapc:~$ nmap -sV -sC -p 22,80,31337 scanme.org -oN nmap_results.txt
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-07-08 16:55 UTC
Nmap scan report for scanme.org (45.33.32.156)
Host is up (0.24s latency).
Other addresses for scanme.org (not scanned): 2600:3c01::f03c:91ff:fe18:bb2f
rDNS record for 45.33.32.156: scanme.nmap.org

PORT      STATE SERVICE      VERSION
22/tcp    open  ssh          OpenSSH 6.6.1p1 Ubuntu 2ubuntu2.13 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|   1024 ac:00:a0:1a:82:ff:cc:55:99:dc:67:2b:34:97:6b:75 (DSA)
|   2048 20:3d:2d:44:62:2a:b0:5a:9d:b5:b3:05:14:c2:a6:b2 (RSA)
|   256 96:02:bb:5e:57:54:1c:4e:45:2f:56:4c:4a:24:b2:57 (ECDSA)
|_  256 33:fa:91:0f:e0:e1:7b:1f:6d:05:a2:b0:f1:54:41:56 (ED25519)
80/tcp    open  http         Apache httpd 2.4.7 ((Ubuntu))
|_ http-favicon: Nmap Project
|_ http-server-header: Apache/2.4.7 (Ubuntu)
|_ http-title: Go ahead and ScanMe!
31337/tcp open  tcpwrapped
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 16.95 seconds
manic@salapc:~$

```

Port	State	Service	Version
22/tcp	open	ssh	OpenSSH 6.6.1p1 Ubuntu 2ubuntu2.13
80/tcp	open	http	Apache httpd 2.4.7 ((Ubuntu))

GOBUSTER ENUMERATION

Command used:

```

gobuster dir -u http://nmap.org -w /usr/share/wordlists/dirb/common.txt -o
gobuster_results.txt

```

```

Unpacking dirb (2.22+dfsg-sbuild2) ...
Setting up dirb (2.22+dfsg-sbuild2) ...
Processing triggers for man-db (2.12.0-4build2) ...
manic@salapc:~$ ls /usr/share/wordlists/dirb/common.txt
ls: cannot access '/usr/share/wordlists/dirb/common.txt': No such file or directory
manic@salapc:~$ gobuster dir -u http://nmap.org -w /usr/share/wordlists/dirb/common.txt -o gobuster_results.txt
=====
Gobuster v3.6
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] Url:             http://nmap.org
[+] Method:          GET
[+] Threads:         10
[+] Wordlist:         /usr/share/dirb/wordlists/common.txt
[+] Negative Status codes: 404
[+] User Agent:      gobuster/3.6
[+] Timeout:         10s
=====
Starting gobuster in directory enumeration mode
=====
Error: the server returns a status code that matches the provided options for non existing urls. http://nmap.org/850010bb-ccd8-4d87-8489-0594a3100ba5 => 301
(Length: 334). To continue please exclude the status code or the length

```

RISK ANALYSIS

Rate each finding by Likelihood x Impact to arrive at an overall risk rating.

<u>Finding</u>	<u>Likelihood</u>	<u>Impact</u>	<u>Risk Rating</u>
Exposed Administrative Endpoints	High	High	High
Outdated Apache HTTP Server Banner (v2.4.7)	Medium	Medium	Medium
Outdated OpenSSH Daemon Banner (v6.6.1p1)	Medium	Medium	Medium
Expanded Subdomain Attack Surface (17 Subdomains)	High	Low	Medium
Unresponsive Service Access (tcpwrapped Port 31337)	Low	Low	Low

SOURCE TOOLS: Subfinder, Nmap, Shodan, Gobuster

RECOMMENDATIONS:

- Patch/upgrade outdated service versions identified in Nmap scan.
- Restrict or remove publicly accessible directories/files found via Gobuster (e.g. [/admin, /backup]).
- Disable unnecessary open ports not required for business function.
- Reduce information exposed via WHOIS using registrar privacy protection.
- Regularly monitor Shodan for newly exposed assets.

CONCLUSION:

1. How many subdomains were discovered?

17 sub-domains were discovered

2. Which subdomain was most interesting and why?

The most interesting discovery in this scan is **changeme.nmap.org**. Based on its name, one could easily guess that it is a leftover from the default installation process which has not been changed and renamed accordingly. Such default settings are valuable to the attacker because it usually means that anyone will be able to access the testing environment with weak/default credentials. Another interesting result is the group of typo-like entries. They seem to be created intentionally to protect against typos but are worth revisiting.

3. Which service would you investigate first?

Port 22 (SSH, OpenSSH 6.6.1p1 on Ubuntu). It's the oldest, SSH is a direct remote-access vector — if any known CVE applied to this exact build, it would be the highest-impact path in.

4. Which Gobuster finding was most valuable?

The discovery of **/admin** and **/login** endpoints were most valuable because it exposed **public-facing authentication gateways**, which could give an attacker **a direct vector to attempt credential brute-forcing or bypass mechanisms to compromise the web application**.

5. What does the attack surface look like overall?

The overall attack surface is **moderate**: 2 open ports (SSH, HTTP) **17** discovered subdomains (**changeme**), and a web server whose Gobuster results should be double-checked against the exec summary's **admin/login** claim. No CVEs were flagged by **Shodan**, and the exposed services, while outdated in version number, are consistent with a deliberately-maintained public test target rather than an unmanaged production system.

6. What would your next steps be if given additional time?

To conduct a complete vulnerability scan using either OpenVAS or Nessus, which will help us determine any vulnerabilities (CVE) associated with our specified OpenSSH and Apache software versions, we will need to manually check for each of the subdomain status and functions, as well as do further web enumeration by using a greater word list as well as manual tests, including the use of Burp Suit..